CTDMS v1.2

What was fixed – plain-language report

Second testing round · 27 September 2026 · prepared for Samarth Tulsyan

6 / 6	9	97 / 97	0
problems from the Astra report fixed	extra weak spots found by re-checking – fixed	automatic checks passing	error pages under heavy use (was 2)

In one minute

- Another testing tool (GPT Astra) found **6 problems** my first test round missed. **All 6 are fixed** in v1.2.
- I then had a separate reviewer check my fixes from scratch. It found **8 weak spots** (7 in my fixes, 1 older one), and I found **1 more** while testing the upgrade. All 9 are fixed too.
- **Your data is safe.** Nothing is deleted or reset. On first start v1.2 adds one small column to the database by itself (details on page 8).
- **Speed with many users:** the worst wait went from **30 seconds to under 3**, and the "Something went wrong" pages under heavy use are gone.
- **What you will notice:** transporter PDFs now open (long LR lists move to a notes section at the end), and start_demo.bat explains clearly what it is doing or what went wrong.
- **Still open:** a few small items (page 8). None blocks daily use.

How to read this report
Each fix has the same five parts: what was wrong, a real-life example, what I changed, the proof, and a blue box that explains any technical words. A full word list is on the last page.

The 6 problems at a glance

The last column answers your question: would turning CTDMS into a desktop .exe have fixed it by itself? Mostly no – these were problems in the app's own logic, so they had to be fixed in the code (and the fixes carry over to an .exe).

#	What was wrong (plain words)	Risk for the business	Status	.exe alone?
1	A fake "ID" line in a request switched off the check that proves a save came from a CTDMS screen	Low–medium: needs you logged in and visiting a bad website	**Fixed**	**Mostly yes**
2	Resetting a password from the command window did not log out old logins	Medium: a stolen laptop or ex-employee could keep access	**Fixed**	**No**
3	Transporter PDF crashed once a transporter had many LR numbers	High for daily work: month-end report unusable	**Fixed**	**No**
4	The data feed for other software stopped at 2,000 pending invoices without saying so	Medium, later: a connected ERP would miss invoices	**Fixed**	**No**
5	An empty database file made the demo logins fail ("right password, still rejected")	Low: confusing first start	**Fixed**	**No**
6	Slow pages and error pages when many people use it at the same time	Medium with 5+ users; none with 1 user	**Much better**	**Partly**

Astra's IDs: 1 = QA-07, 2 = QA-03, 3 = QA-10, 4 = QA-11, 5 = QA-09, 6 = QA-13. The other 8 items in Astra's report were already in my first report and fixed in v1.1 – except two that were only partly improved there: narrow phone screens, and the "secure cookie" setting (see What is still open).

Fix 1 of 6 · Astra ID QA-07 · Security

A fake header could switch off a security check

What was wrong

Every save made from a CTDMS screen carries a hidden security code (a **CSRF token**) that proves it really came from CTDMS. The part of the app that other software talks to (the **API**) skipped this check whenever the request contained an "Authorization" line – **even a fake one**.

Real-life example

You are logged in to CTDMS in Chrome and open a harmful website in another tab. In theory that page could make your browser quietly send "import this invoice" to CTDMS, and CTDMS would accept it as coming from you. (Modern browsers make this particular trick hard, so the real risk was low – but the door was unlocked.)

What I changed

- The app now looks at **how you actually logged in**, not at which lines the request happens to contain.
- Logged in through the browser → the security code is always required.
- Software using an API password (a **token**) → the token alone decides; a fake token = "not logged in".

Proof

- Before: fake header → invoice imported. After: blocked. Tested with 3 kinds of fake headers.
- Real screens and real API users still work (tested).

Tech words used here
CSRF – short for Cross-Site Request Forgery: a trick where a harmful website makes your browser send an action to another site you are logged in to.
CSRF token – a random secret code on every CTDMS form; a harmful website cannot know it.
API – the "back door for software": how other programs (ERP, scripts) talk to CTDMS without screens.
Token – a password-like pass that software uses to log in to the API.

Fix 2 of 6 · Astra ID QA-03 · Security

Password recovery did not log out old logins

What was wrong

If you are locked out, CTDMS has a command-window tool to reset the admin password. It changed the password but **left every existing login working** – a browser left logged in, or an API token. It could even turn any user into an admin without asking.

Real-life example

An employee's laptop is stolen while CTDMS is open. You reset that account's password. Before v1.2, the thief's open browser still worked. If that account was also made admin, the thief got admin rights too.

What I changed

- Recovery now **logs the account out everywhere** (all browsers + all API tokens), clears a lockout and writes an entry in the audit log.
- Turning a normal user into an admin needs an extra, deliberate word: `--promote`.
- Also: deactivating a user or changing their role logs them out everywhere, and their old tokens **stay dead even if the account is switched on again later**.

Proof

- Old API token: worked → now refused. Old browser: worked → now sent to the login page.
- Without `--promote` the tool refuses and changes nothing (tested).

Tech words used here
Command window / CLI – typing commands instead of clicking; used for admin rescue tasks.
Session – the "you are logged in" memory the app keeps for your browser.
Audit log – CTDMS's permanent diary of who did what and when.

Fix 3 of 6 · Astra ID QA-10 · Daily work

Transporter PDF crashed with many LR numbers

What was wrong

The transporter-wise report lists all LR numbers of a transporter inside **one table cell**. Once a transporter had roughly 100+ dispatches, that one cell became taller than a whole page and the PDF maker gave up – you saw "500 Something went wrong".

Real-life example

Month-end: accounts opens the transporter-wise PDF to check Chhattisgarh Roadlines' bill – error page instead of the report. (Excel and CSV still worked, which hid the problem.)

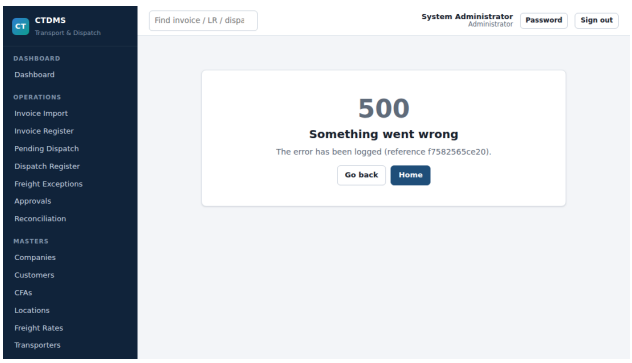
What I changed

- Lists with more than 10 items now show as "131 items – full list in note [1] below"; the complete list is printed in a **Notes** section after the table. **Nothing is dropped.**

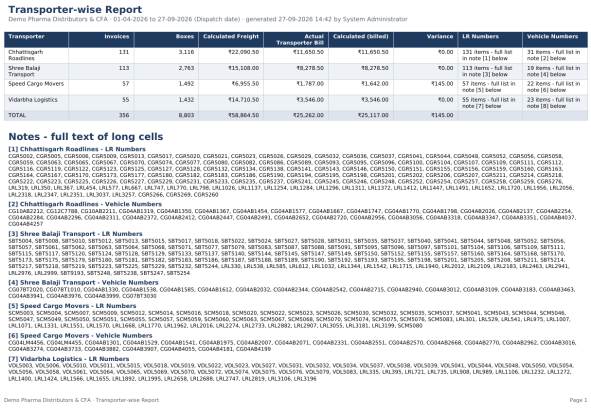
- The same protection now applies to every report PDF.
- Excel can only hold 32,767 characters in one cell and used to cut longer lists **silently**. CTDMS now cuts at a clean point and writes how many items are missing and where to find them (CSV / Dispatch Register).

Proof

- Same 3,300-invoice test data: v1.1 → error page; v1.2 → 2-page PDF (below). A test with 3,000 LR numbers in one cell checks that every single one appears in the PDF.



Before (v1.1): error page



After (v1.2): summary table + notes

Tech words used here
PDF maker (ReportLab) – the component that draws report PDFs page by page.
Error 500 – the web's code for "the app itself broke" – always a bug, never the user's fault.

Fix 4 of 6 · Astra ID QA-11 · Integrations (later)

The pending-invoice feed stopped at 2,000 without saying so

What was wrong

Other software can ask CTDMS "which invoices are still waiting for dispatch?". The answer was cut at **2,000 invoices** with no warning that more existed.

Real-life example

With 2,951 invoices waiting (our test data), a connected ERP or dashboard would have seen only 2,000 and assumed that was everything – **951 invoices silently missing**. CTDMS's own screens were never affected.

What I changed

- The answer now comes in **pages** (500 at a time) and always says the **total** and whether there is **more**.
- A **bookmark** ("cursor") lets software read everything exactly once, even while dispatches happen in between – page numbers alone can shift, the bookmark cannot.
- Note: the answer's format changed. Nothing has been built on it yet, so nothing needs updating today.

Proof

- Before: a list of 2,000 (no total). After: first page of 500, total 2,951, "has more" = yes; reading all pages returns each invoice exactly once (tested, also while invoices are being dispatched).

Tech words used here
Pagination – handing out a long list in pages, like search results.
Cursor – a bookmark saying "continue after this invoice".

Fix 5 of 6 · Astra ID QA-09 · Setup

An empty database file broke the first login

What was wrong

start_demo.bat only checked whether the database **file** existed, not whether anything was **inside** it. An empty file (for example left over from an interrupted setup) was used as it was: the login page showed demo accounts that did not exist, so the right password was rejected.

Real-life example

Astra linked this to the "correct password, still rejected" problem seen earlier on your laptop.

What I changed

- The launcher now **looks inside** the database: empty → loads the demo data; **any real data → never reset**, only its structure updated; data but no user account → it stops and prints the exact command to create an admin.
- It also stops with a clear message – and the window **stays open** so you can read it – if Python is missing, the internet is down while installing, or CTDMS is already running.

Proof

- Checked: empty file, file with data (kept exactly), data without users (nothing changed), and upgrading a real v1.1 database (all 300 invoices and edits kept, login works).

What you will now see in the black window on a normal start:

```
Checking required packages...
Database ready: 9 active users, 3,300 invoices. Existing data kept as it is.

 CTDMS is starting at http://127.0.0.1:8000
 Keep this window open while you use CTDMS. Close it to stop the app.
```

Tech words used here
Launcher (.bat file) – the double-click file that installs and starts CTDMS on Windows.
Migration – an automatic, data-keeping update of the database's structure (e.g. adding a column).

Fix 6 of 6 · Astra ID QA-13 · Speed

Slow pages and errors with many users at once

What was wrong

The small built-in database (**SQLite**) lets only **one person save at a time**. v1.1 made even **viewing** a page wait for that "save turn". So everyone queued behind everyone – under heavy use some people waited 30 seconds and then got an error page.

Real-life example

Think of one billing counter. v1.1 made people who only wanted to look at the price list stand in the billing queue too. v1.2 lets them look freely; only people who are paying (saving) queue.

What I changed

- Viewing no longer waits for anyone. Only saving takes turns.

- If a view still bumps into a save (rare), it is quietly tried once more – but **never** if it had already saved something, so nothing can be saved twice.
- Exports read the data and build the file without blocking others; they only take the turn for the one-line audit note at the end.

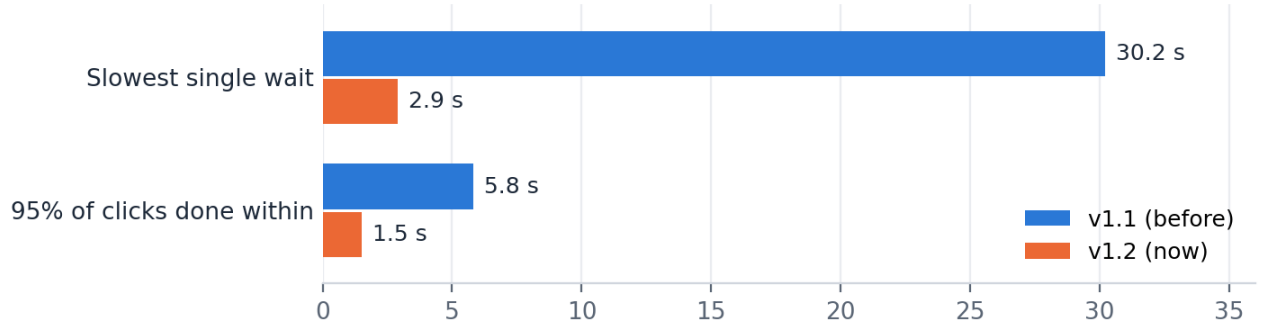
Proof

- Chart on the next page (same 3,300-invoice data, same computer, before vs after).
- Correctness under load, checked: 10 people importing the **same** invoice at once → saved once; 10 clicks on "generate slip" at once → exactly 1 slip; no duplicate slip numbers; database health check OK.

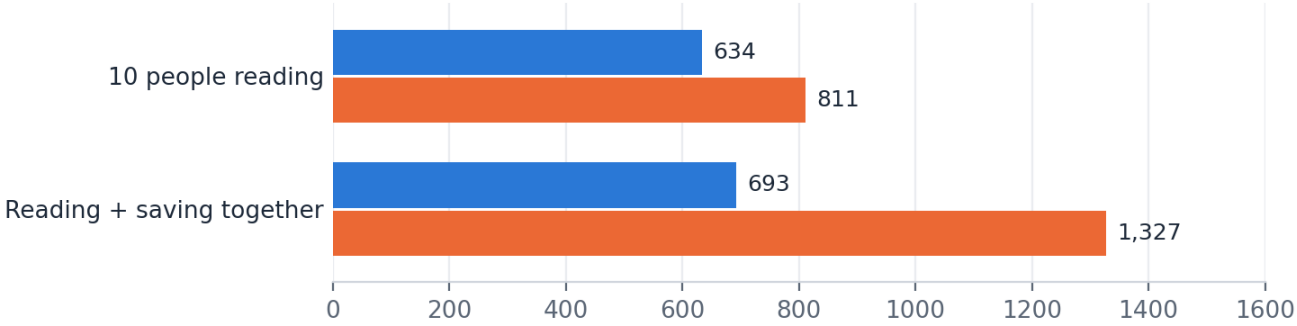
Tech words used here
SQLite – the one-file database CTDMS uses on a single computer. PostgreSQL is the bigger server version.
Lock – the "save turn": while one person saves, others wait a moment.
Load test – a robot that plays many users clicking at once, to measure speed and errors.

Speed: before vs after

Waiting time with 10 people clicking at once (seconds, lower is better)



Work handled in the same test time (requests, higher is better)



Test: 3,300 invoices, one CTDMS process on one computer, simulated users clicking through dashboard, invoices, pending dispatch and reports. "Reading + saving together" also completed 60 full dispatches during the test.

Honest notes

- Under heavy load the typical click got slower (about 0.04 s → 0.7 s): before, most clicks went first while a few waited 30 s; now everyone shares the computer fairly. With 1–2 users you will not notice – a single user's pages actually got faster (95% of clicks within 0.42 s → 0.19 s).
- 10 people clicking non-stop is far more than normal office use; it is a stress test.
- One CTDMS process on one computer handles about 13–15 clicks per second. For many users or several sites, use the server set-up with PostgreSQL (see docs/DEPLOYMENT.md).

Extra weak spots found by re-checking my fixes

After fixing the 6 problems I asked a separate reviewer – with no knowledge of my reasoning – to try to break the fixes. It found 8 weak spots (7 in my fixes, 1 older one); I found 1 more while testing the upgrade. All 9 are fixed and each has its own automatic check.

#	Weak spot (plain words)	Fixed how
1	A page could wait up to 90 s and then fail, when the app updated your "last seen" time while someone else was saving.	That small update now waits at most 0.25 s, or is skipped and done on the next click.
2	The automatic retry could record an export twice in the audit log.	Never retried once anything was saved.
3	Reading the invoice feed page by page could skip an invoice if another one was dispatched in between.	Added the bookmark (cursor) method; absurd page numbers now get a clear error instead of a crash.
4	My first CSRF fix preferred the browser login over a valid API token – it broke some legitimate API use.	A valid token now decides; a fake one means "not logged in".
5	Switching a user off and on again brought their old API tokens back to life.	New "sign-out stamp" per user (the small database addition).
6	If CTDMS failed to start, the Windows window closed before you could read why.	It now pauses and explains (e.g. "already running in another window").
7	PDF notes could print a long list twice, or show the word "None".	Labels fixed.
8	Non-English characters in the security code caused an error page (old issue).	Now a normal "access denied".
9	(found by me) Starting v1.2 on a v1.1 database: the start-up check looked for the new column before adding it, so the app would not start.	Order fixed; an automatic test now upgrades a v1.1 database every time.

How much was tested

- **97 automatic checks** run on the small database (SQLite) – all pass. On the server database (PostgreSQL 16): 95 pass, 2 are SQLite-only and skipped.
- **26 of them are new** for v1.2. The checks for Astra's 6 problems were run on v1.1 first: every problem check **failed on v1.1** (so it really catches the problem) and passes on v1.2.
- Astra's exact steps were replayed on v1.1 and v1.2 side by side on a 3,300-invoice copy: all reproduced on v1.1, all fixed on v1.2.

How to install v1.2 on your laptop

About 5 minutes. Your data stays where it is – the download does not contain a database.

1. **Stop CTDMS:** close the black CTDMS window.
2. **Back up (recommended):** copy `ctdms\data\ctdms.db` to your Desktop.
3. **Unzip** `ctdms-v1.2.zip`.
4. **Copy** everything from the unzipped `ctdms` folder into your current folder `C:\Users\Admin\Downloads\ctdms-v1.0claudeapp\ctdms` and choose **Replace** when Windows asks.
5. **Double-click** `start_demo.bat`. On this first start it updates the database structure by itself and should print "Database ready … Existing data kept as it is."
6. **Log in** as usual. To confirm the version, open `http://127.0.0.1:8000/health` – it should say `"version": "1.2.0"`.

If something goes wrong

- The window now stays open with a message – read it first; it says what to do.
- To go back: close the window, copy your backup `ctdms.db` back into `ctdms\data\` and use the v1.1 files again.

What is still open

- **From the first report (v1.1):** an approved but not yet paid transporter bill can still be rejected by a second approver (REC-03) – a small rule change, suggested next.
- **If CTDMS is ever put on the internet:** switch on the "secure cookie" setting (`CTDMS_SESSION_COOKIE_SECURE=true`, needs HTTPS) and limit login attempts per computer at the server level. Not needed while it runs only on your laptop.
- **Phones:** wide tables still scroll sideways on small screens.
- **Not tested yet (needs the real thing):** real printer output, live SAP / MARG / CBO / Intrect connections (tests used simulated ERP data), and an internet-facing server with HTTPS.
- **Your .exe idea:** all fixes are in the app's code, so they carry over to an .exe. A single-user .exe also removes the CSRF-type risk (fix 1) and the many-users slowness (fix 6) by design. If several people must share the same data, a small office server is still the better route.

Word list

Every technical word used in this report, in plain language.

Word	Meaning
API	The "back door for software" – how other programs (an ERP, a script) talk to CTDMS without screens.
Audit log	CTDMS's permanent diary of who did what and when (imports, exports, approvals, logins).
Bearer token / JWT	A password-like pass that software shows on every request to the API. JWT is its format.
Browser session / cookie	How the app remembers that your browser is logged in. The cookie is the small note the browser keeps for it.
Command window / CLI	Typing commands instead of clicking. Used for admin rescue tasks like `create-admin`.
CSRF	Cross-Site Request Forgery: a harmful website making your browser send an action to a site you are logged in to.
CSRF token	A random secret code on every CTDMS form that a harmful website cannot know.
Cursor (bookmark)	"Continue after this item" – lets software read a long list in pages without skipping anything.
Database / SQLite / PostgreSQL	Where all CTDMS data lives. SQLite = one file on one computer. PostgreSQL = a database server for many users.
Error 500 / 401 / 403 / 422	Web answer codes: 500 = the app broke (a bug); 401 = not logged in; 403 = not allowed; 422 = the request was filled in wrongly.
Header	A labelled line sent along with every web request (e.g. "Authorization: ..."), invisible to users.
Launcher (.bat)	The double-click file that installs and starts CTDMS on Windows.
Load test	A robot that plays many users clicking at once, to measure speed and errors.
Lock	The database's "save turn": while one person saves, others wait a moment.
Migration	An automatic, data-keeping update of the database's structure (e.g. a new column).
Pagination	Handing out a long list in pages, like search results.
p95 ("95% within")	95 out of 100 clicks finished within this time; only the slowest 5 took longer.
Regression test	An automatic check that a fixed problem never comes back.
Retry	Trying an action again automatically after a temporary hiccup.